

EASM AEGIS

External Attack Surface Assessment Report

test.com

65/100

Risk Level: HIGH

Report ID: RPT-05FE9C7C4C9B

Target: test.com

Organization: Test Corp

Scan Date: 2026-04-12T18:00:00

Generated On: 2026-04-12T19:00:00

Prepared By: EASM AEGIS Security Platform

Classification: CONFIDENTIAL

*This document contains sensitive security findings.
Unauthorized distribution is prohibited.*

Table of Contents

1. Executive Summary	4
2. Attack Surface Overview	5
3. Methodology & Scope	6
4. Reconnaissance Results	7
5. Asset Discovery - Subdomains	8
6. Subdomain Takeover Risk Assessment	9
7. Port & Service Analysis	10
8. Web Asset Analysis	11
9. SSL/TLS Analysis	12
10. Technology Fingerprinting	13
11. Vulnerability Findings	14

12. Threat Intelligence Context	CONFIDENTIAL - FOR AUTHORIZED RECIPIENTS ONLY	16
13. Email & People Intelligence		17
14. Risk Score - Transparent Breakdown		18
15. Remediation Roadmap		19
16. Change Analysis (Delta)		20
17. Appendix		21

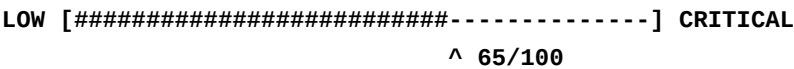
1. Executive Summary

The assessment of test.com identified 5 vulnerabilities across 8 live hosts, including 1 critical and 2 high-severity issues. 1 of these vulnerabilities are listed in CISA's Known Exploited Vulnerabilities catalog and require immediate attention. Additionally, 1 employee email addresses were found in known data breaches. The overall risk score is 65/100 (HIGH).

Key Metrics

Metric	Value
Subdomains Discovered	12
Live HTTP Assets	8
Open Ports	45
Total Vulnerabilities	5
Critical CVEs	1
High CVEs	2
CISA KEV Matches	1
Avg EPSS Score	0.97
Exposed Emails	3
Breached Emails	1
Risk Score	65/100 [HIGH]

Risk Gauge



Business Impact

The security posture has notable gaps. High-severity vulnerabilities and exposed services increase the probability of compromise. Remediation should be prioritized within the current sprint cycle.

2. Attack Surface Overview

Discovery

Total Subdomains Found	2
Live / Resolving Hosts	1
Dead / Unresolved	1

Network Exposure

Total Open Ports	3
Unique Services Running	3
Dangerous Ports Exposed	1 (!)

Web Presence

HTTP Assets Discovered	2
HTTPS Assets	1
HTTP Only (No Encryption)	1 (!)

Vulnerabilities

Total CVEs Found	5
Critical	1 (!)
High	2 (!)
Medium	1
Low	1
CISA KEV Matches	1 (!)
Average EPSS Score	0.97

Intelligence

Emails Discovered	3
Emails in Breaches	1 (!)
Shodan Exposed Services	1

OVERALL RISK SCORE: 65/100 [HIGH]

3. Methodology & Scope

3.1 Assessment Approach

The assessment combines Passive Reconnaissance (no direct contact with the target - uses Shodan, Censys, WHOIS, cert.sh, theHarvester) and Active Scanning (direct interaction - port scanning via Naabu, HTTP probing via HTTPX, vulnerability scanning via Nuclei). Passive recon carries zero legal risk. Active scanning was performed against authorized targets only.

3.2 Tools Used

Tool	Type	Purpose
Subfinder	Passive	Subdomain enumeration
Amass	Passive	DNS enumeration & OSINT
Shodan API	Passive	Internet-wide service data
Censys API	Passive	Certificate transparency & TLS
WHOIS	Passive	Domain registration data
theHarvester	Passive	Email & people OSINT
Hunter.io API	Passive	Email discovery
LeakCheck API	Passive	Breach database correlation
Naabu	Active	TCP port discovery
HTTPX	Active	HTTP probing & tech fingerprinting
Nuclei	Active	Template-based vuln detection
NVD / NIST	Enrichment	CVE details & CVSS scoring
FIRST EPSS	Enrichment	Exploitation probability
CISA KEV	Enrichment	Known exploited vulns list

3.3 Compliance Framework Alignment

Findings are mapped to the following compliance controls where applicable:

Framework	Controls	Scope
SOC 2 Type II	CC6.1, CC6.6, CC6.7, CC7.1	Access Controls & Security Events
ISO 27001:2022	A.8.8, A.8.9, A.12.6, A.14.2	Technical Vulnerability Mgmt
PCI-DSS v4.0	Req 6.2, 6.3, 11.3	Vuln Scanning & Secure Dev
OWASP Top 10	A01-A10:2021	Web Application Risks

3.4 Scope Definition

In-Scope:	test.com and all discovered subdomains
Out-of-Scope:	Third-party CDN infrastructure, WAF-protected endpoints
Scan Start:	2026-04-12T18:00:00
Scan End:	2026-04-12T18:30:00

4. Reconnaissance Results

4.1 WHOIS & Domain Intelligence

Registrar:	GoDaddy
Creation Date:	2015-03-12
Expiry Date:	2026-05-12
Updated Date:	N/A
Name Servers:	ns1.test.com, ns2.test.com
DNSSEC:	Not configured (!)
Privacy:	Exposed (!)

WARNING: DOMAIN EXPIRING SOON

Domain expires in 30 days. Risk of expiry hijacking.

WHOIS Risk Flags

- Domain expiring within 60 days
- DNSSEC not configured

4.2 Shodan Intelligence

Shodan identified 1 hosts, 1 services, and 1 potential CVEs.

IP	Port	Service	Product
1.2.3.4	443	https	nginx 1.18

4.3 Censys Intelligence

Censys identified 1 hosts and 0 services with TLS/certificate data.

5. Asset Discovery - Subdomains

2 subdomains were discovered for test.com. Every subdomain represents a potential attack entry point.

Discovery Sources

Source	Subdomains Found
subfinder	1
crtsh	1

Subdomain Summary

Subdomain	IP	Sources
api.test.com	1.2.3.4	subfinder
old.test.com	None	crtsh

6. Subdomain Takeover Risk Assessment

Subdomain takeover occurs when a subdomain's DNS record points to a third-party service (AWS S3, GitHub Pages, Heroku, Azure) that has been deleted or unclaimed. An attacker can claim the service and serve malicious content under your domain.

Note: Automated subdomain takeover detection is not yet integrated into the scanning pipeline. The following is a manual assessment based on DNS analysis of discovered subdomains.

Potential Dangling Subdomains (1)

Subdomain	IP	Action
old.test.com	None	Investigate

These subdomains have no IP or are unresponsive. Verify DNS records and remove if unused.

7. Port & Service Analysis

3 open ports were discovered across all hosts.

Dangerous Ports (1)

DANGEROUS PORT - 3389 (RDP)			
Host:	srv.test.com		
Service:	rdp		
Risk:	RDP - Remote Desktop		
Remediation:	Close or restrict access to this port.		

Port Summary

Host	Port	Service	Risk
api.test.com	443	https	Standard
api.test.com	22	ssh	Standard
srv.test.com	3389	rdp	Dangerous

8. Web Asset Analysis

2 HTTP assets were discovered and probed.

8.1 Response Code Distribution

Status Code	Count
200	1
403	1

8.2 HTTP Assets Detail

URL	Status	Title
https://api.test.com	200	API
http://old.test.com	403	Forbidden

9. SSL/TLS Analysis

TLS configuration is a direct compliance requirement for PCI-DSS, SOC2, and ISO 27001. Weak TLS versions (1.0, 1.1) are deprecated and prohibited under PCI-DSS v4.0.

Detailed TLS/SSL analysis data is not yet available. Configure Censys API integration for comprehensive certificate and protocol analysis.

HTTPS Coverage

HTTPS Assets	1
HTTP-Only Assets	1 (!)
HTTPS Coverage	50.0%

10. Technology Fingerprinting

3 unique technologies were detected across the target's web assets. Outdated technologies may harbor unpatched vulnerabilities.

Technology	Occurrences
nginx	5
jQuery	3
PHP	2

11. Vulnerability Findings

11.1 Vulnerability Statistics

Severity	Count	SLA	Action Required
CRITICAL	1	24-48 hrs	Immediate executive attention
HIGH	2	7 days	Urgent patch/remediation
MEDIUM	1	30 days	Planned remediation
LOW	1	90 days	Scheduled maintenance
INFO	0	-	Informational only

CISA KEV ALERT: 1 known exploited vulnerabilities detected

These vulnerabilities are confirmed to be actively exploited by real attackers.
Immediate patching is required per CISA BOD 22-01.

11.2 Critical & High - Detailed Finding Sheets

FINDING #1 | CRITICAL | CVE-2021-41773

Name: Apache RCE
Host: srv.test.com
EPSS: 0.97 (top 97%)
KEV Status: IN CISA KNOWN EXPLOITED LIST
Controls: PCI-DSS Req 6.3

Description:
Path traversal

Remediation: Upgrade

FINDING #2 | HIGH | CVE-2023-1234

Name: Open Redirect
Host: api.test.com

Remediation: Validate URLs

FINDING #3 | HIGH | No CVE

Name: Info Disclosure

Host: api.test.com

Remediation: Hide version

11.3 MEDIUM Findings (1)

Finding	Host	CVE
Missing HSTS	old.test.com	-

11.3 LOW Findings (1)

Finding	Host	CVE
Cookie flag	api.test.com	-

12. Threat Intelligence Context

12.1 CVE Threat Context

1 CVEs are in CISA's Known Exploited Vulnerabilities catalog, meaning they are actively used by real threat actors.

The average EPSS score of 0.97 indicates a HIGH probability that these vulnerabilities will be exploited within 30 days.

12.2 Breach Intelligence Correlation

1 employee emails were found in known data breaches. If password reuse exists, attackers may use these credentials for VPN, admin panels, or cloud services.

13. Email & People Intelligence

13.1 Email Exposure Summary

Metric	Count
Total Emails Discovered	3
Breached	1
Clean	1
Unchecked	1
Password Leaks	1
Breach Rate	33.3%

13.2 Discovered Emails

Email	Source	Breached	Pwd Leaked
admin@test.com	hunter	Yes	Yes
user@test.com	theharvester	No	No
info@test.com	whois	No	No

13.3 Breach Details (1 emails)

BREACH - admin@test.com	
Found In:	RockYou2024
Pwd Leaked:	Yes
Remediation:	Force password reset. Enable MFA immediately.

14. Risk Score - Transparent Breakdown

The risk score is a weighted composite of multiple factors. This section shows exactly how the score was calculated for auditability.

14.1 Scoring Components

Factor	Value	Points
Critical CVEs	1	40 (x40 each)
High CVEs	2	50 (x25 each)
Medium CVEs	1	10 (x10 each)
Low CVEs	1	3 (x3 each)
Info CVEs	0	0 (x1 each)
Subdomains > 50	2	0
Ports > 100	3	0
HTTP Assets > 20	2	0
Breached Emails	1	+5

Total (capped at 100): 65/100 - HIGH

14.2 What Drove the Score

- 1 Critical CVEs contributing 40 points
- 2 High CVEs contributing 50 points
- 1 actively exploited vulnerabilities (CISA KEV)
- 1 dangerous ports exposed
- 1 employee emails in data breaches

15. Remediation Roadmap

Immediate - 0 to 48 Hours (Stop the Bleeding)

#	Action	Controls
1	Patch CVE-2021-41773 Apache RCE	PCI-DSS Req 6.3, SOC2 CC6
2	Force password reset for admin@test.com	SOC2 CC6.1

Short Term - 1 to 7 Days

#	Action	Controls
1	Close RDP port 3389 on srv.test.com	PCI-DSS Req 1.1.6

Medium Term - 8 to 30 Days

#	Action	Controls
1	Enable HSTS on all web assets	SOC2 CC6.7

16. Change Analysis (Delta)

2 changes were detected since the last scan.

Recent Changes

Type	Details	Detected At
new_subdomain	new.test.com appeared	2026-04-10
port_closed	FTP port 21 closed	2026-04-09

17. Appendix

Appendix A - Complete Subdomain List

Subdomain	IP	Sources
api.test.com	1.2.3.4	subfinder
old.test.com	None	crtsh

Appendix B - Full Port/Service Table

Host	Port	Service	Status
api.test.com	443	https	open
api.test.com	22	ssh	open
srv.test.com	3389	rdp	open

Appendix C - Scan Execution Log

Scan ID: N/A
Status: completed
Started: 2026-04-12T18:00:00
Completed: 2026-04-12T18:30:00

Phase Execution:

recon: done
scan: done

Appendix D - Glossary

Term	Definition
EPSS	Exploit Prediction Scoring System - probability of exploitation in 30 days
KEV	Known Exploited Vulnerabilities - CISA catalog of confirmed exploited CVEs
CVSS	Common Vulnerability Scoring System - severity rating 0.0-10.0
CNAME	Canonical Name DNS record - alias pointing to another domain
TLS	Transport Layer Security - encryption protocol for web traffic
OSINT	Open Source Intelligence - publicly available information gathering
SOC 2	Service Organization Control 2 - trust service criteria audit framework
PCI-DSS	Payment Card Industry Data Security Standard